

LAB-SDLC-IA-SEC · PONTO 1

Objetivo, princípios e técnicas

Ciclo de vida de desenvolvimento seguro e DevSecOps

Mesma ordem do README: objetivo → princípios → técnicas

Três seções, sempre nesta ordem

1. Objetivo

O que a fase tem que entregar. Atividade fica aqui.

2. Princípios

A regra que não pode quebrar. Uma linha por regra.

3. Técnicas

Só método com nome na literatura, com quem e ano.

Sem nome na literatura, não é técnica. Catálogo e processo ficam fora da tabela.

OBJETIVO DO PONTO

O que este ponto entrega

Entrega

SDLC seguro: seis fases, técnica de cada uma, DevSecOps no ciclo.

Não é

Teste de segurança no final.

Quanto mais cedo a segurança entra, mais barato é corrigir. Falha no commit custa horas; em produção, dias.

Requisitos

Entrega	Ativos classificados e requisitos de segurança verificáveis.
----------------	--

Ativos	Dados, segredos, funções, infra. Passo, não técnica.
---------------	--

Classificação	Público, Interno, Confidencial, Restrito.
----------------------	---

CIA	Confidencialidade, Integridade, Disponibilidade.
------------	--

Tipo	Funcional, não funcional, restrição.
-------------	--------------------------------------

Requisitos

Verificabilidade	Se não dá para testar, não serve.
Rastreabilidade	Ativo → requisito → controle → teste.
Negação explícita	O que não deve acontecer vira requisito negativo.

Ruim: "seja seguro". Bom: "rota autenticada rejeita token expirado com 401".

Requisitos

Abuse case McDermott e Fox, 1999. Outsider quebra, rouba ou derruba.

Misuse case Sindre e Opdahl, 2000. Insider faz o que não deve.

Confuse case Insider erra sem intenção.

Attack tree Schneier. Objetivo na raiz; cada ramo é um caminho.

Bug bar Microsoft SDL. Limiar do que não pode ir para release.

Design

Entrega

Arquitetura segura, antes do código.

Fase mais barata para corrigir. Design errado custa uma reunião; código errado custa meses.

Design

Least privilege	Mínimo de acesso por componente.
Defense in depth	Várias camadas; uma falha não derruba tudo.
Fail secure	Erro nega acesso. O oposto é fail open.
Zero trust	Verificar sempre, inclusive na rede interna.

Design

Fluxo de dados Base para aplicar o princípio a cada elemento.

Superfície de ataque Listar entradas e priorizar por risco.

STRIDE não entra aqui. Fica no ponto 2, modelagem de ameaças.

O resto do ciclo

Implementação	Código sem falha conhecida. SAST no commit.
Verificação	SAST, DAST, SCA, pentest. Cada um testa uma camada.
Operação	CVE que afeta o que roda, resposta, patch sem queda.
Descontinuação	Dado removido, credencial revogada, transferência controlada.

Como o ciclo roda

Shift-left

SAST no push, SCA na dependência, secrets antes do merge.

Shift-right

Monitorar em produção o CVE que afeta o que roda.

Pipeline

Commit, build, teste, análise, staging, DAST, produção.

Se uma verificação falha, o pipeline para. SDLC é o processo. DevSecOps é a prática.

Uma linha por seção

Objetivo O que entregar. Atividade não é técnica.

Princípios A regra que não quebra.

Técnicas Método com nome e fonte.

Apresentação segue o README. Se divergir, o README manda.